

Nombre: Luis Alberto Vargas Gonzalez

Fecha: 02/12/2025

Actividad y unidad: U7 A2 Estudio de caso: El protocolo SSL y sus ataques.

Clase: Criptografía.

Maestría en Ciberseguridad.

Índice.

- 1. Portada.**
- 2. Introducción a la investigación.**
- 3. Funcionamiento del protocolo en el caso específico.**
- 4. Uso del protocolo en el caso del “E-Commerce”.**
- 5. Análisis de ataques y defensas.**
- 6. Evolución de SSL en el sector.**
- 7. Conclusiones.**

Estudio de Caso: Análisis de Seguridad y Protocolo SSL/TLS en E-Commerce

Contexto Seleccionado: Tienda Departamental en Línea ("TechMart MX"). **Objetivo:** Proteger la confidencialidad e integridad de las transacciones financieras y datos personales de los clientes.

1. Antecedentes del Protocolo SSL

Es crucial distinguir que "SSL" es el término coloquial heredado, pero técnicamente obsoleto.

- **Origen:** Desarrollado por **Netscape** en 1994 para asegurar las comunicaciones en la web incipiente.
- **Versiones:**
 - **SSL v1.0:** Nunca salió al público por graves fallas de seguridad.
 - **SSL v2.0 (1995):** Lanzado públicamente, pero contenía vulnerabilidades criptográficas serias.
 - **SSL v3.0 (1996):** Un rediseño completo. Fue el estándar durante años hasta que se descubrió la vulnerabilidad POODLE en 2014.
- **Transición:** El IETF (Internet Engineering Task Force) tomó el relevo y lo renombró a **TLS (Transport Layer Security)** en 1999.

Aunque hoy usamos TLS 1.2 o 1.3, seguimos diciendo "Certificado SSL" por costumbre.

2. Funcionamiento del Protocolo en "TechMart MX"

En el contexto de nuestra tienda en línea, el protocolo funciona mediante un proceso de "**Handshake**" (**Apretón de manos**).

Imaginemos que un cliente va a comprar una laptop:

1. **Client Hello:** El navegador del cliente contacta al servidor de TechMart MX y le dice: "Quiero comprar de forma segura, soporto TLS 1.2 y 1.3, y estos algoritmos de cifrado".
2. **Server Hello:** El servidor responde eligiendo la mejor versión de TLS y envía su **Certificado Digital** (validado por una Autoridad Certificadora, CA).
3. **Autenticación:** El navegador verifica que el certificado sea válido (no expirado, emitido por una CA confiable y coincidente con el dominio `techmart.mx`).
4. **Intercambio de Llaves:** Utilizando criptografía asimétrica (llave pública del servidor), negocian una **llave de sesión simétrica**.
5. **Túnel Cifrado:** A partir de aquí, todos los datos (número de tarjeta, dirección, carrito de compras) viajan encriptados con esa llave simétrica. Si alguien intercepta el tráfico, solo verá "basura" ilegible.

3. Usos del Protocolo en el E-Commerce

En una tienda departamental, el SSL no es opcional, es un requisito de negocio y cumplimiento:

- **Protección de Datos Financieros (PCI-DSS):** El estándar de seguridad de tarjetas de pago exige el uso de cifrado fuerte. Sin SSL/TLS, la tienda no puede procesar pagos con Visa/Mastercard legalmente.
- **Autenticación de Usuarios:** Protege las credenciales (usuario/contraseña) durante el login para evitar el robo de cuentas.
- **Integridad del Pedido:** Evita ataques de *Tampering*. Sin SSL, un atacante en la misma red Wi-Fi podría modificar el paquete de datos para cambiar el precio de una TV de \$10,000 a \$10 antes de que llegue al servidor.
- **Confianza del Consumidor (SEO y UX):** Los navegadores modernos marcan como "No Seguro" a los sitios HTTP, lo que derrumba las ventas inmediatamente.

4. Análisis de Ataques y Estrategias de Defensa

Tipo de ataque	Descripción en contexto E-Commerce	Estrategia de defensa
SSL Stripping	Un atacante (Man-in-the-Middle) intercepta la conexión inicial HTTP y fuerza al usuario a mantenerse en HTTP mientras el atacante habla HTTPS con el banco/tienda.	Implementar HSTS (HTTP Strict Transport Security): Obliga al navegador a rechazar cualquier conexión que no sea segura, incluso si el usuario escribe "http".
Downgrade Attack (ej. POODLE)	El atacante engaña al servidor para que use una versión vieja y vulnerable del protocolo (como SSL v3.0) para luego romper el cifrado.	Deshabilitar protocolos obsoletos: Configurar el servidor web (Nginx/Apache) para rechazar conexiones SSL v3, TLS 1.0 y 1.1. Solo permitir TLS 1.2 y 1.3.
Ataques a la CA	Si un atacante compromete a la Autoridad Certificadora, puede emitir certificados falsos para techmart.mx.	Certificate Pinning / CAA Records: Mecanismos para especificar qué autoridades pueden emitir certificados para tu dominio.
Mixed Content	La página de pago es HTTPS, pero carga imágenes (logos) por HTTP. Esto rompe el candado de seguridad.	Auditoría de Contenido: Asegurar que todos los recursos (imágenes, scripts, CSS) se carguen bajo HTTPS.

5. Evolución hacia Nuevos Algoritmos y Conclusiones

Evolución: El protocolo ha evolucionado de proteger la conexión a proteger la privacidad y la velocidad:

- **TLS 1.3 (El estándar actual):** A diferencia del 1.2, reduce el tiempo del "Handshake" (haciendo la tienda más rápida) y elimina algoritmos de cifrado débiles (como SHA-1 o RC4). Implementa **Perfect Forward Secrecy (PFS)** por defecto, lo que significa que si roban la llave privada del servidor hoy, no pueden descifrar el tráfico capturado hace un mes.
- **Criptografía Post-Cuántica:** Se están estandarizando nuevos algoritmos resistentes a computadoras cuánticas (NIST) para futuras versiones de TLS, previendo que la criptografía actual (RSA/ECC) podría ser rota en la próxima década.

Conclusiones:

En el estudio de caso de "TechMart MX", el protocolo SSL (propriadamente TLS) no es solo una herramienta técnica, sino el cimiento de la viabilidad comercial.

1. **La defensa en profundidad es necesaria:** No basta con instalar un certificado; se debe configurar HSTS y deshabilitar versiones antiguas para evitar ataques de *downgrade*.
2. **Cifrado es igual a Confianza:** En un entorno de compras en línea, la percepción de seguridad es tan importante como la seguridad real.
3. **Vigilancia Continua:** La gestión de certificados (renovación y revocación) es crítica; un certificado vencido detiene las operaciones de la empresa por completo.